bankmate 安全自评报告

银行 AI 智能体参赛材料

队伍名称：哈基米摸南北绿豆　学校：暨南大学

赛题方向：银行 AI 智能体（AI Banking Agent）

材料日期：2026 年 10 月 8 日　项目版本：0.1.0

自评结论

bankmate 已将查询与资金变更分开，并在后端实施白名单、严格参数、固定参数确认、当前账务复核、事务执行和重复确认去重。自动化测试表明这些机制在既定本地沙箱场景中有效。

当前版本定位为单身份本地模拟演示。浏览器连接不等于真实用户登录，未实现多用户 RBAC、独立管理员、真实银行认证或不可篡改审计。现有实现不应作为真实资金服务的安全准入结论。

1 自评范围与资产

资产	保护目标
模拟账户与持仓	变更可确认、可复核、仅执行一次
计划与资金承诺	跨会话一致，旧版本不能直接执行
对话及联系人信息	最少对外传递，减少手机号暴露
模型与飞书凭证	只在服务端使用，不进入前端或提交包
确认与流水记录	保存操作依据、状态、回执和关联 ID

范围包括 Web API、模型工具路径、计划与资金执行、SQLite 存储及飞书本地适配。真实模型服务的安全能力、飞书线上权限、终端操作系统安全及真实银行接口不在本次离线验证覆盖范围内。

验证概况

2026 年 10 月 8 日完成后端静态检查、65 项 pytest 用例和实际 HTTP/SSE 检查，前端 build 通过。未执行浏览器交互、真实模型或真实飞书联调，也未开展外部渗透测试。

2 信任边界与威胁模型

用户输入、模型输出、历史引用、联系人名称和交易备注都应视为不可信数据。模型负责提议工具和参数，后端负责验证能力及执行资格。浏览器、模型服务、飞书桥接和本地数据库各形成独立边界。

威胁	可能结果	已实现控制
模型越权工具	执行代码、SQL 或未知业务	仅接受 TOOLS 白名单；未知工具终止任务
伪造工具参数	改金额、跳过确认或注入额外权限	严格类型与 extra=forbid；确认参数由服务端保存
提示注入	用商户备注或联系人文本授予权限	数据标记与提示约束；实际变更仍走后端确认
重复确认或回调	多次扣款或多次入账	确认状态、操作唯一 ID、到账与渠道事件去重
确认后状态变化	花费已被冻结或预留的资金	确认事务重查余额、承诺、卡片、日限额与产品风险
旧页面与会话混淆	在错误会话确认旧需求	Web 确认检查原会话；新需求取消旧待确认操作
隐私与凭证暴露	向模型或浏览器暴露敏感信息	已知手机号替换或脱敏；密钥只由后端读取
服务中断	重启后重复业务或丢失执行结果	结果落盘；running 标记失败，不自动重放

不可信数据的处理

模型协议校验只证明工具计划的格式与参数符合约束，不证明用户意图一定被正确理解。用户必须核对确认卡上的收款实体、金额和操作类别；后端以已保存参数执行，而不是再次解析模型自由文本。

3 权限分级实现

下列分级描述当前能力与执行流程，不将演示风险等级 R1 至 R4 当成用户访问角色。Web 的所有有效连接共享同一个演示身份，当前没有管理员与普通用户的强隔离。

层级	允许能力	实施位置	限制
L0	健康检查及连接初始化	main.py health、bootstrap	bootstrap 自动发连接令牌，不是账户登录
L1	查询、诊断和资金预演	session、Bank.query、TOOLS	只读账务；预演保存草稿元数据
L2	交易、状态、计划及承诺变更	Bank.prepare、Agent.confirm、Bank.execute	用户点击确认；15 分钟有效；当前状态再校验
L3	重置、载入演示、模拟工资入账	sandbox 专用接口	有连接与专用字段检查，但没有独立管理员角色
模型	提议上述工具名称与参数	ModelClient 与 Agent	不能调用确认接口或自由执行 SQL 和代码
桥接	转发已绑定飞书私聊与卡片	bridge 与 feishu_event	Bearer 密钥及租户 用户 私聊标识匹配

3 1 身份与请求来源

bank_session 使用随机令牌，数据库只保存 SHA256；Cookie 为 HttpOnly、SameSite=Strict，HTTPS 时设置 Secure。API 校验令牌存在，支持恢复浏览器选中会话。Cookie 的 30 天寿命是浏览器侧配置，服务端没有令牌年龄失效检查。

API 对携带 Origin 的请求只接受指定的 localhost 与 127.0.0.1 地址；缺失 Origin 的请求仍可进入连接校验。防跨站配置降低本地误用风险，但不能代替真实登录或完整的 CSRF 设计。

3 2 沙箱管理边界

重置使用 confirmation=RESET，载入缺口场景使用 confirmation=LOAD_DEMO。它们防止界面误操作，但不能构成管理权限认证。模拟工资事件会增加沙箱余额，这类直接业务测试入口仅适合本地演示。真实服务应限制或移除此类入口。

4 交易安全与执行保护

4 1 固定参数与二次复核

准备阶段验证对象和参数，收款人重名不能生成有效转账确认。通过检查后保存实际收款实体 ID、金额及摘要。确认请求仅提交 confirm 或 cancel 与原会话 ID，不允许从确认请求另传金额、对象或 bypass 字段。

执行前按当前数据重新检查余额、已安排资金、卡片状态、累计日支付限额、产品起购额和风险匹配。诊断卡即使显示 ready，也不跳过最终复核；持仓与计划版本发生变化时同样可能阻止执行。

4 2 去重与事务

同一确认 ID 只允许 pending 状态执行。BEGIN IMMEDIATE 保证写入互斥，SAVEPOINT 将单项资金变更隔离；成功状态与回执和账务一起提交。重复请求读取已有回执，模型请求和卡片重发不重新记账。

风险点	可运行验证	验证结论
未经确认扣款	test_transfer_requires_confirmation_and_writes_receipt	确认前余额不变，确认后才写回执
并发重复扣款	test_simultaneous_confirmation_is_idempotent	8 路确认只扣一次并返回同一回执
过期确认	test_expired_approval_cannot_execute	超过 15 分钟后不执行
状态变化	test_balance_is_revalidated_at_confirmation	余额改变后拒绝旧卡片执行
伪造确认字段	test_unknown_tool_and_fake_confirmation_cannot_execute	未知工具及额外参数不获授权

4 3 中断与部分完成

组合任务按步执行，一项失败停止后续，已经完成的操作保留并向用户说明完成数量。该行为未实现跨多笔交易的整体回滚。服务重启不重放处理中断的模型请求；失败后用户应先核对回执，再决定是否重新发起业务。

5 数据隐私渠道与审计

5 1 数据最小化

模型上下文中的已知联系人手机号替换为稳定联系人 ID，其他符合手机号模式的数字隐藏；查询结果返回脱敏号码和尾号。最多取最近 30 条界面消息组成新任务历史，结构化历史数据有长度上限。内部异常不直接暴露上游正文或凭证。

原始用户消息仍会保存到本地 SQLite，交易描述和对话语义也可能包含姓名、地址等信息。当前脱敏主要覆盖手机号，不等于完整个人信息识别。模型服务可见本轮必要对话与工具结果；使用真实资料前应另行确定外部数据授权、保留和删除政策。

5 2 飞书绑定与重放保护

飞书默认关闭。启用时，桥接令牌要求至少 32 字符，后端采用恒定时间比较验证 Bearer 凭证。绑定码为随机值，哈希存储、10 分钟有效、使用一次即删除；绑定同时核验 tenant_key、open_id 和 chat_id，只处理文本私聊及卡片回调。

入站 event_id 保存处理结果，重复事件不重复创建任务。发送端按消息 ID 维护 outbox，发送失败不会再次执行银行业务。Web 与飞书均使用同一审批事务；飞书可确认该演示身份的原操作，真实多账户服务仍需更细的主体与对象授权。

5 3 审计记录与留存

记录	可追踪信息
tasks 与 messages	需求、任务状态、错误、数据卡和确认卡
approvals	工具、固定参数、创建及到期时间、最终状态和回执
transactions	账户、金额、方向、业务时间与操作 ID
plan_versions 与 executions	版本输入、预演结果、关联确认及目标完成额
events 与 trigger_runs	SSE 序号、到账和条件触发处理依据

删除会话保留已执行银行交易；重置演示会清理聊天、任务、确认、计划与账务并重新生成数据。审计记录存于普通 SQLite，没有签名、外部备份或不可篡改存证，重置之前应保留所需评审证据。

6 已知风险清单

等级按当前单机演示用途判断。下列改进均属于尚未完成项；不将建议性控制写成已实现能力。

编号	等级	已知风险	现有边界与后续处理
R01	高	单身份，无真实登录与多租户隔离；初始化自动发连接令牌	限制本机访问；真实服务需账户认证与对象级授权
R02	高	沙箱重置与模拟入账没有独立管理员角色	仅本地模拟；真实环境移除或分离管理接口
R03	中	缺失 Origin 仍可访问；无独立 CSRF 令牌	保留 SameSite 与来源检查；补严格跨站请求方案
R04	中	连接令牌仅校验存在，服务端无年龄失效与主动撤销流程	本地使用；补服务端 TTL、注销与会话轮换
R05	中	数据库明文存储原始对话，脱敏主要覆盖手机号	只用模拟数据；补数据分级、加密及完整脱敏规则
R06	中	提示注入可能影响解释或误导工具建议	后端强制确认与白名单；扩展对抗语料及意图核对
R07	中	模型请求与结果依赖外部服务，尚无真实联调指标	离线验证替身；提交前单独检验超时、协议和数据范围
R08	中	普通 SQLite 审计可修改，重置会清理业务证据	重置前备份；补访问控制、保留策略和外部审计

风险处理优先顺序

继续本地演示时优先保护凭证、保存提交快照并完成手动交互核验。准备接入真实数据或公网前，先处理身份及对象授权、管理入口和数据保护，再扩展模型与流量治理。

7 业务与验证剩余风险

编号	等级	已知风险	处理建议
R09	中	固定业务日期与按当前月份生成的种子流水可能不一致，自动工资与房租推断为空	固定场景显式说明假设；后续对齐种子日期并补日期回归
R10	中	压力挑战为单因素；同日事件粒度和联动风险尚未充分覆盖	明确搜索范围；补逐事件回放和多因素组合验证
R11	中	多步骤任务部分完成后不整体回滚	回执披露完成步骤；按真实业务要求设计补偿
R12	低	单个模型工作队列可能使长请求阻塞其他会话	保持步数和超时上限；补队列限流及负载测量
R13	中	只有本地模拟的飞书绑定与回调检查，真实私聊未联调	启用前验证发布权限、租户身份、卡片和发送失败
R14	低	前端交互、无障碍和跨浏览器行为尚未经本次检查	构建已通过；团队手动检查焦点、卡片与错误提示

7 1 安全用例的证据范围

test_banking.py 验证未经确认、重复确认、过期、精度、未知工具、数据注入、失败后不重付及卡片业务约束。test_api.py 验证连接来源与篡改字段、模型未配置、沙箱重置、飞书绑定去重和跨渠道确认。

test_conversations.py 验证上下文分离、原会话确认、删除后保留资金数据、处理中保护及迁移。test_diagnostics.py 验证多阻碍只读诊断、确认后复核、证据来源和手机号脱敏。test_planning.py 验证承诺释放、现金流缺口、单因素边界、到账去重、固定日期及分期。test_llm.py 验证协议兼容、上游错误脱敏、无依据总结拒绝和格式纠正。

7 2 结论使用范围

本报告是参赛作品的自评和风险披露，不包含生产级安全认证。已实现控制与自动化结果适用于所列代码快照和模拟场景；真实服务的认证、权限、数据与交易控制需要独立设计和重新验证。